

Szablon analizy:

1. Zadanie domowe:

1. Nazwa incydentu

LastPast

2. Organizacja i rok

Do dnia dzisiejszego nie ma informacji o konkretnej grupie , która jest odpowiedzialna za atak publiczny z 2022 r.

I atak – sierpień 2022

Sprawca włamał się do firmowego laptopa inżyniera oprogramowania wykorzystując lukę w oprogramowaniu, uzyskał dostęp do środowiska programistycznego w chmurze i ukraść kody źródłowe .

I atak zakończył się 12 sierpnia 2022

Sprawca uzyskał dostęp do:

- repozytoriów oprogramowania i kodu źródłowego na żądanie, w chmurze to 14 z 200 repozytoriów oprogramowania
- wewnętrznych skryptów z repozytoriów – zawierały sekrety i certyfiakty LastPass
- dokumentacji wewnętrznej – informacje techniczne opisujące sposób działania środowiska programistycznego

II atak - od 12 sierpnia 2022 r. do 26 października 2022 r.

Sprawca włamał się do komputera starszego inżyniera DevOps, wykorzystując luki w systemie innych firm, dostarczył złośliwe oprogramowanie omijając zabezpieczenia aby uzyskać nieautoryzowany dostęp do kopii zapasowych w chmurze. Dane jakie uzyskał z tych kopii zapasowych obejmowały dane konfiguracyjne systemu, tajne klucze API, tajne klucze integracji z systemami innych firm oraz zaszyfrowane i niezaszyfrowane dane klientów LastPASS.

Sprawca uzyskał dostęp do:

- **DevOps Secrets** – zastrzeżone sekrety, które zostały wykorzystane do uzyskania dostępu do magazynu kopii zapasowych w chmurze

- **przechowywanych kopii zapasowych w chmurze**, które zawierały dane konfiguracyjne, sekrety API, sekrety integracji stron trzecich, metadane klienta oraz kopie zapasowe wszystkich danych w sejfie klienta. Dane poufne w sejfie klienta, poza adresami URL, ścieżkami plików do zainstalowania oprogramowania LastPass dla systemu Windows lub macOS oraz niektóre adresy e-mail – zaszyfrowane za pomocą unikalnego klucza szyfrującego . Jednak firma twierdzi, że hasła główne użytkowników końcowych nie są znane LastPass i nie są przechowywane ani utrzymywane.

- **dostęp do kopii zapasowych baz danych LastPasss MFA/Federation**

3. Profil atakującego

Zaawansowany cyberprzestępca (Advanced Persistent Threat / wysoce wykwalifikowany adwersarz) – atak był starannie zaplanowany, wieloetapowy i trwał kilka miesięcy

Sprawca charakteryzował się następującymi cechami:

- **doskonałą znajomością procesów DevOps** – był wymierzony w konkretnych pracowników z uprzywilejowanym dostępem, co sugeruje rozpoznanie organizacji – obrał za cel jednego z 4 inżynierów DevOps, który miał dostęp do kluczy deszyfrujących potrzebnych do uzyskania dostępu do usługi przechowywania danych w chmurze

Sprawca:

- **posiadał dobrą znajomość środowisk** chmurowych – potrafił wykorzystać dostęp do AWS (Amazon Web Serwis) , zarządzać poświadczeniami i uzyskać dostęp do kopii zapasowych
- **Umiejętności z zakresu kradzieży poświadczeń** – wykorzystał keylogger oraz inne techniki przejmowania danych uwierzytelniających.
- **był niezwykle cierpliwy i posiadał dyscyplinę operacyjną** – prowadził długotrwałą infiltrację

4. Wektor wejścia

Wektor wejścia (initial access) czyli dostęp początkowy do ataku na LastPass

Etap 1 – atak na środowisko deweloperskie**Taktyka Mitre – Initial Access**

Technika – Valid Accounts – wykorzystanie prawidłowych kont – napastnik uzyskał dostęp do środowiska deweloperskiego poprzez przejęte konto dewelopera.

W następnym etapie – kradzież kodu źródłowego i dokumentacji

Efektem było pozyskanie architektury systemu

Dokładna metoda nie została ujawniona dlatego nie jesteśmy w stanie określić technik jakich użył czy to był phishing (T1566) czy exploit public facing application (T1190)

Etap 2 – wykorzystanie zdobytych informacji**Taktyka Mitre – Initial Access – dostęp początkowy**

Technika T1190 – Exploit Public -Facing Application – wykorzystanie podatnej aplikacji dostępnej z internetu – włamywacz wykorzystał lukę w aplikacji multimedialną działającą na komputerze domowym starszego inżyniera DevOps, uzyskując możliwość zdalnego wykonania kodu

Następnym etapem była instalacja prawdopodobnie keyloggera i kradzież poświadczeń

Efekt kradzież kopii sejfów klienta.

Taktyka Mitre :

- Credential Access (dostęp do poświadczeń)– Input Capture - keylogging (T1056.001) (przechwytywanie danych wejściowych)
- Credential Access – Credentials from Password Stores T1555 (poświadczenia z magazynów haseł)– dostęp do firmowego sejfu LastPass – atakujący wyszukają lokalizacje przechowywanych haseł aby uzyskać dane uwierzytelniające użytkowników
- Discovery (rozpoznanie)– Account Discovery – t1087 – czyli odkrycie konta
- Collection – Data from Information Repositories – T1213 – wykorzystanie danych z repozytoriów informacji
- Exfiltration (eksfiltracja) – Exfiltration to Cloud Storage – T1567 – ekfiltracja przez usługę internetową

5. Cel działania

I atak :

Sprawca wykorzystując lukę w zabezpieczeniach oprogramowania na firmowym komputerze programisty uzyskał dostęp do środowiska programistycznego w chmurze i ukradł kody źródłowe. Zdobył również informacje techniczne oraz niektóre wewnętrzne poufne informacje systemowe LastPass.

II atak

Sprawca zaatakował firmowy komputer jednego z czterech inżynierów DevOpsa wykorzystując podatny na ataki system innych firm aby dostarczyć złośliwe oprogramowanie, ominąć istniejące zabezpieczenie i ostatecznie uzyskać nieautoryzowany dostęp do kopii zapasowych w chmurze. Dane jakie uzyskał to dane konfiguracyjne systemu, tajne klucze API, tajne klucze integracji z systemami innych firm oraz zaszyfrowane i

niezaszyfrowane dane klientów LastPass.

6. Naruszone elementy CIA

1. Poufność (Confidentiality)

Doszło do naruszenia poufności, ponieważ atakujący uzyskał dostęp do danych przechowywanych przez LastPass czyli:

- zaszyfrowanych sejfów użytkowników
- do metadanych użytkowników
- ujawniono część informacji niezabezpieczonych szyfrowaniem (np. adresy URL zapisanych stron)

2. Integralność (Integrity) – mogła być naruszona ale nie jest potwierdzona – integralność oznacza ochronę danych przed nieautoryzowaną zmianą

nie wykazano aby doszło do zmian hasła użytkowników, jakiś wpisów w bazach danych czy modyfikowania sejfów użytkowników.

Jednakże atakujący uzyskali dostęp do systemów wewnętrznych i mogli ingerować w niektóre zasoby.

7. Etap Co wydarzyło się w incydencie?

Klasyfikacja według MITRE ATT&CK

Można ten atak opisać następującymi technikami:

Etap 1 – atak na środowisko deweloperskie

Taktyka Mitre – Initial Access

Technika – Valid Accounts – wykorzystanie prawidłowych kont – napastnik uzyskał dostęp do środowiska deweloperskiego poprzez przejęte konto dewelopera.

W następnym etapie – kradzież kodu źródłowego i dokumentacji

Efektem było pozyskanie architektury systemu

Dokładna metoda nie została ujawniona dlatego nie jesteśmy w stanie określić technik jakich użył czy to był phishing (T1566) czy exploit public facing application (T1190)

Etap 2 – wykorzystanie zdobytych informacji

Taktyka Mitre – Initial Access – dostęp początkowy

Technika T1190 – Exploit Public -Facing Application – wykorzystanie podatnej aplikacji dostępnej z internetu – włamywacz wykorzystał lukę w aplikacji multimedialną działającą na komputerze domowym starszego inżyniera DevOps, uzyskując możliwość zdalnego wykonania kodu

Następnym etapem była instalacja prawdopodobnie keyloggera i kradzież poświadczeń

Efekt kradzieży kopii sejfów klienta.

Taktyka Mitre :

– Credential Access (dostęp do poświadczeń)– Input Capture - keylogging (T1056.001) (przechwytywanie danych wejściowych)

- Credential Access – Credentials from Password Stores T1555 (poświadczenia z magazynów haseł)– dostęp do firmowego sejfu LastPass – atakujący wyszukają lokalizacje przechowywanych haseł aby uzyskać dane uwierzytelniające użytkowników

- Discovery (rozpoznanie)– Account Discovery – t1087 – czyli odkrycie konta, Odkrywanie plików (File Discovery – T1083)

- Lateral Movement (przemieszczanie się w sieci) – wykorzystanie przejętych poświadczeń

- Collection (gromadzenie danych)– Data from Information Repositories – T1213 – wykorzystanie danych z repozytoriów informacji

- Exfiltration (eksfiltracja) – Exfiltration to Cloud Storage – T1567 – ekfiltracja przez usługę internetową – eksfiltracja danych do magazynów w chmurze

Sprawca pozyskał następujące dane:

W ramach włamania nr 1:

- Dostęp do repozytoriów oprogramowania i kodu źródłowego na żądanie, w chmurze – dotyczyło to 14 z 200 repozytoriów oprogramowania.
- Dostęp do wewnętrznych skryptów z repozytoriów, które zawierały sekrety i certyfikaty LastPass.
- Dokumentację wewnętrzną – informacje techniczne opisujące sposób działania środowiska programistycznego.

W ramach włamania nr 2:

- DevOps Secrets – zastrzeżone sekrety, które zostały wykorzystane do uzyskania dostępu do naszego magazynu kopii zapasowych w chmurze.
- Dostęp do przechowywanych kopii zapasowych w chmurze, które zawierały dane konfiguracyjne, sekrety API, sekrety integracji stron trzecich, metadane klienta oraz kopie zapasowe wszystkich danych w sejfie klienta.
- Dostęp do poufnych danych w sejfie klienta, poza adresami URL, ścieżkami plików do zainstalowanego oprogramowania LastPass dla systemu Windows lub MacOS oraz do niektórych adresów e-mail, które były szyfrowane przy użyciu odpowiedniego modelu – mogły zostać odszyfrowane tylko za pomocą specjalnego klucza.
- Dostęp do kopii zapasowych bazy danych LastPass MFA/Federation, która zawierała kopie seedów LastPass Authenticator, do numerów telefonów, które były użyte do utworzenia kopii zapasowej MFA (jeśli włączono), a także podzielony komponent wiedzy („klucz K2”) używany do federacji LastPass (jeśli włączono).

Jak się okazało baza danych była zaszyfrowana a klucz deszyfrujący został również skradziony.

8. Co poszło nie tak po stronie obrońców?

Po przeanalizowaniu formy ataku można stwierdzić, że błędem była:

- niewystarczająca ochrona kont uprzywilejowanych – przejęcie konta pracownika umożliwiło atakującemu dostęp do środowiska wewnętrznego, konta z wysokimi uprawnieniami powinny być dodatkowo chronione – np. poprzez ograniczenie dostępu, ciągły monitoring
- napastnik po uzyskaniu dostępu mógł dotrzeć do zasobów
- niewystarczające zabezpieczenie stacji roboczej pracownika DevOps
- brak szybkiego wykrycia nietypowej aktywności – atak był długotrwały

9. Gdzie można było przerwać incydent?

Incydent można było zatrzymać na kilku etapach:

1. Na etapie przejęcia komputera programisty – atak nr 1
 - o zastosowanie silnego uwierzytelniania wieloskładnikowego (MFA),
 - o wykrycie nietypowego logowania (np. z nowej lokalizacji lub urządzenia),
 - o automatyczne blokowanie podejrzanych sesji.
2. Na etapie dostępu do środowiska deweloperskiego
 - o ograniczenie uprawnień zgodnie z zasadą najmniejszych uprawnień (Least Privilege),
 - o kontrola dostępu do kodu i infrastruktury,
 - o monitoring aktywności kont uprzywilejowanych.
3. Na etapie ataku na komputer DevOps
 - o system EDR/XDR mógł wykryć instalację keyloggera,
 - o programista powinien mapować system aby wykryć nieprawidłowości
 - o regularne aktualizacje oprogramowania zmniejszyłyby ryzyko wykorzystania podatności,
 - o izolacja urządzenia po wykryciu podejrzanej aktywności.
4. Na etapie dostępu do kopii zapasowych

- o dodatkowe zabezpieczenie kluczy szyfrujących,
- o oddzielenie systemu backupów od środowiska administracyjnego,
- o powinien być zainstalowany program, który informuje o zbytnim pobieraniu danych

Brak komunikacji między programistami? Jeżeli ktoś widzi niedozwolony ruch to powinien konsultować to z innymi.

10. Trzy rekomendacje bezpieczeństwa

1. Wzmocnienie zabezpieczenia dla wszystkich kont, zasobów
2. Lepsza ochrona urządzeń pracowników
 - ciągle monitorowanie podejrzanych procesów i logowań
 - szybkie reagowanie na anomalie
3. Lepsze zabezpieczenie danych i kopii zapasowych np. poprzez rotację i ochronę kluczy szyfrujących, izolacji systemów backupowych

Techniki jakie można by było zastosować :

Zastosowanie bezpieczeństwa:

Inwentaryzacja węzłów sieciowych , która pozwala na identyfikację i rejestrowanie wszystkich węzłów sieciowych Inwentaryzacja węzłów sieciowych (hostów, routerów, przełączników, zapór sieciowych itp.) w architekturze organizacji.

Mapowanie sieci : Ocena podatności sieci , która polega na porównaniu wszystkich podatności komponentów sieci w kontekście ich konfiguracji i wzajemnych zależności.

Może również obejmować ocenę ryzyka wynikającego z projektu sieci jako całości, a nie tylko sumy podatności poszczególnych węzłów sieci lub segmentów sieci.

Mapowanie systemu: Mapowanie wymiany danych , która identyfikuje i modeluje zamierzony przez organizację projekt przepływów typów, formatów i woluminów danych między systemami na poziomie aplikacji.

Jakie zastosowano zabezpieczenia po atakach?

po I ataku:

- Usunięto środowisko programistyczne i zbudowano nowe, aby zagwarantować pełne powstrzymanie i wyeliminowanie sprawcy zagrożenia.
- Wdrożono dodatkowe technologie bezpieczeństwa i kontroli w celu uzupełnienia istniejących kontroli.
- Dokonano rotacji wszystkich istotnych tajnych informacji w postaci zwykłego tekstu używanych przez nasze zespoły oraz wszelkich ujawnionych certyfikatów.

Po II ataku:

- Przeprowadzono analizę zasobów pamięci masowej w chmurze LastPass i zastosowano dodatkowe zasady i środki kontroli.
- Przeanalizowano i zmieniono istniejące kontrole dostępu uprzywilejowanego.
- Wymieniono istotne sekrety i certyfikaty, do których uzyskał dostęp sprawca zagrożenia.